

Threat Intelligence & IOC

Obiettivo:

Analizzate la cattura attentamente e rispondere ai seguenti quesiti:

- Identificare ed analizzare eventuali IOC, ovvero evidenze di attacchi in corso
- In base agli IOC trovati, fate delle ipotesi sui potenziali vettori di attacco utilizzati
- Consigliate un'azione per ridurre gli impatti dell'attacco attuale ed eventualmente un simile attacco futuro

Analisi pacchetti

La macchina 192.168.200.100 ha iniziato una serie di connessioni TCP SYN verso 192.168.200.150, coinvolgendo porte note come:

- 22 (SSH)
- 80 (HTTP)
- 443 (HTTPS)
- 135, 139, 445 (SMB / NetBIOS)

Ogni pacchetto presenta payload nullo (Len = 0), fatto che suggerisce una scansione silenziosa.

Anche i campi del pacchetto (es. Window Size = 64240, timestamp variabili) indicano l'utilizzo di strumenti automatici di scansione.

Subito dopo, la macchina target ha risposto con numerosi pacchetti RST/ACK, comportamento comune quando:

- un servizio è chiuso
- oppure si utilizza un honeypot per simulare vulnerabilità e tracciare comportamenti malevoli.

Lista delle porte contattate:

- 22
- 80
- 443
- 135
- 139
- 445

Considerazioni sui log:

I pacchetti analizzati mostrano un'attività di tipo TCP SYN scan, una tecnica utilizzata per individuare servizi attivi sulle macchine bersaglio. Il comportamento rilevato – pacchetti SYN su porte comuni, risposte RST/ACK, e assenza di payload – è fortemente compatibile con l'uso di Nmap o strumenti simili.

Inoltre, l'identità dell'host target ("METASPLOITABLE") conferma che l'attaccante è alla ricerca di sistemi vulnerabili.

Macchina attaccante:

Dall'analisi di vari header dei pacchetti si deduce che la macchina attaccante utilizza Linux (es. Window_size = 64240, timestamp attivi).

Il pattern delle porte di origine (alte e casuali) e l'ordine delle opzioni TCP sono ulteriori indizi dell'impiego di Nmap.

Azioni consigliate:

🔔 Attivare logging e alert su connessioni SYN anomale

Monitorare e bloccare IP che mostrano comportamenti simili è cruciale per evitare escalation.

Un attaccante, dopo la scansione, potrebbe tentare un exploit.

🔒 Ridurre la superficie di attacco

Chiudere tutte le porte non essenziali, come SMB o SSH, soprattutto su macchine esposte. Questo limita l'efficacia delle scansioni anche se avvengono.

👤 Honeypot e fingerprinting attaccanti

Utilizzare honeypot configurati appositamente può rallentare e ingannare l'attaccante.

Nel frattempo è utile raccogliere dati sul profilo dell'attacco per rispondere in modo più mirato in futuro.

Conclusione:

La raccolta di evidenze suggerisce che l'evento osservato è una scansione TCP SYN effettuata con Nmap.

Non sono stati rilevati exploit diretti, ma è fondamentale intervenire per impedire eventuali fasi successive dell'attacco.